

Clase 157 — Threat intelligence a partir de malware

Parte: **6 — Análisis de malware** · Fuente: MITRE ATT&CK, *Intelligence-Driven Incident Response* (Roberts & Brown) 🕒 Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Transformar el análisis de una muestra en **inteligencia accionable**: IOCs estructurados, TTPs mapeados, pivoteo hacia infraestructura y campañas relacionadas, y atribución razonada. El alumno aprenderá a usar la Pyramid of Pain, marcos como Diamond Model y ATT&CK, y a producir inteligencia que otros equipos puedan consumir (STIX, MISP).

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Distinguir** niveles de IOC según la Pyramid of Pain y su valor.
2. **Estructurar** inteligencia con Diamond Model, ATT&CK y STIX/TAXII.
3. **Pivotar** desde una muestra hacia infraestructura y muestras relacionadas.
4. **Evaluar** atribución con hipótesis y confianza, evitando conclusiones frágiles.
5. **Publicar** inteligencia consumible (MISP, feeds, reglas).

Temas

#	Tema	Por qué importa
1	Datos, información, inteligencia	Diferencia clave del CTI
2	Pyramid of Pain	Prioriza IOCs por impacto en el atacante
3	Diamond Model	Estructura adversario/infra/capacidad/víctima
4	Pivoteo de infraestructura	Amplía de una muestra a una campaña
5	Atribución y confianza	Evita errores caros
6	STIX/TAXII y MISP	Formatos e intercambio
7	IOCs vs TTPs	Durabilidad de la detección

Definiciones y características

- **IOC**: artefacto observable (hash, IP, dominio). Característica clave: **fácil de cambiar** para el atacante (base de la pirámide).
- **TTP**: comportamiento del adversario. Característica clave: **caro de cambiar** (cima de la pirámide).
- **Pyramid of Pain (Bianco)**: jerarquía de indicadores por "dolor" al atacante. Característica clave: **prioriza detección**.
- **Diamond Model**: modelo de eventos de intrusión. Característica clave: **relaciona 4 vértices**.

- **STIX**: lenguaje estructurado para CTI. Característica clave: **interoperabilidad**.

Herramientas y preparación

- **VirusTotal (pivoteo)**, **MalwareBazaar**, **URLhaus**, **ThreatFox** (abuse.ch).
- **MISP** para almacenar y compartir; **STIX2** (Python) para estructurar.
- **MITRE ATT&CK Navigator** para mapear TTPs.
- Passive DNS / WHOIS para pivoteo de infraestructura.

 **Nota ética y de seguridad:** el pivoteo usa fuentes de inteligencia y metadatos; no contactes infraestructura del atacante ni descargues muestras activas fuera del lab. Maneja la inteligencia con clasificación adecuada (TLP) y evita exponer datos de víctimas.

Laboratorio guiado

1. Parte de una muestra ya analizada. Reúne sus IOCs: hashes, dominios/IPs C2, mutex, rutas, certificados TLS.
2. Clasifícalos con la **Pyramid of Pain** y anota cuáles son volátiles (hash/IP) y cuáles duraderos (TTPs, herramientas).
3. Pivotea en VirusTotal/ThreatFox: desde un dominio C2 encuentra otras muestras que lo contactan; desde un imphash halla binarios similares. Documenta las relaciones.
4. Usa passive DNS/WHOIS para expandir la infraestructura (dominios hermanos, ASN, patrones de registro).
5. Construye un **Diamond Model** del evento: adversario (hipótesis), infraestructura, capacidad (la muestra), víctima.
6. Mapea las TTPs al **ATT&CK Navigator** y exporta la capa.
7. Estructura un objeto **STIX** (indicator + malware + relationship) o crea un evento en **MISP** con TLP y tags.
8. Redacta una evaluación de atribución con nivel de confianza (baja/media/alta) y las evidencias que la sostienen.

Ejercicios

1. Ordena 8 IOCs en la Pyramid of Pain y justifica.
2. Pivotea de un dominio a muestras relacionadas y documenta el grafo.
3. Rellena un Diamond Model de un caso real.
4. Exporta una capa de ATT&CK Navigator para una familia.
5. Crea un evento MISP con IOCs, TTPs y TLP.
6. Redacta una hipótesis de atribución con confianza calibrada.

Reto verificable

A partir de una muestra, entrega un **paquete de inteligencia**: IOCs clasificados por la pirámide, capa ATT&CK, grafo de pivoteo con al menos 2 relaciones nuevas y una evaluación de atribución con nivel de confianza. **Criterio de aceptación:** el paquete incluye al menos dos artefactos relacionados descubiertos

por pivoteo (no presentes en la muestra inicial) y una atribución con confianza explícita y evidencia, no una afirmación categórica.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Solo compartir hashes/IPs	Son volátiles; añade TTPs, más duraderos
Atribución categórica	Usa hipótesis y niveles de confianza; evita saltar a conclusiones
Pivoteo sin verificar	Correlaciona varias fuentes antes de afirmar relación
IOCs sin contexto	Añade fechas, TLP y origen para que sean útiles
Exponer datos de víctimas	Anonimiza y respeta TLP al compartir

Preguntas frecuentes

? ¿Por qué priorizar TTPs sobre IOCs? Porque el atacante cambia hashes e IPs con facilidad, pero modificar sus técnicas es costoso; detectar TTPs es más resiliente.

? ¿La atribución es fiable? Es difícil y manipulable (false flags). Se maneja como hipótesis con niveles de confianza, no como certeza.

? ¿Qué es TLP? El Traffic Light Protocol clasifica cómo puede compartirse la información (RED/AMBER/GREEN/CLEAR) para proteger fuentes y víctimas.

Referencias

- Bianco, D. — Pyramid of Pain. <https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html>
- Roberts & Brown — *Intelligence-Driven Incident Response*.
- MISP. <https://www.misp-project.org>
- STIX/TAXII (OASIS). <https://oasis-open.github.io/cti-documentation/>
- MITRE ATT&CK Navigator. <https://mitre-attack.github.io/attack-navigator/>

Siguiente clase

Clase 158 - Emulacion y unpacking automatizado